

MK FRAUD READINESS

Comprehensive management workshop

Turn the recorded assessment into owned decisions,
sequenced actions and a board-ready checkpoint.

Kestrel Industrial Supply (Pty) Ltd

Named reviewer: Named review lead · Review lead

Review date: 11 August 2026

The session should end with decisions, owners and proof

This workshop is a working session, not a read-out. The aim is to challenge the information boundary, decide what management will do and agree what the board should see next.

By the end

- Agree which priority findings reflect the operating reality.
- Confirm what the supplied information does and does not demonstrate.
- Choose treatment options and make ownership explicit.
- Set the next checkpoint and the proof required to close it.

Working boundary

- Do not rewrite the recorded assessment through discussion alone.
- Do not claim operating effectiveness beyond the named scope.
- Do not close an action without operating proof and an effectiveness measure.
- Escalate unresolved disagreements rather than smoothing them over.

Reported readiness: 55.3 out of 100. This workshop changes neither the deterministic score nor maturity.

A 140-minute conversation with a clear output at every stage

TIME	CONVERSATION	PURPOSE	OUTPUT
25 min	Findings challenge	Test whether the recorded findings reflect the operating reality.	Agreed or challenged finding statements
25 min	Information boundary	Surface gaps between recorded answers, supplied artefacts and review notes.	Scope and limitation decisions
20 min	Ownership	Confirm accountable executive, process owner and oversight function.	Named owner map
25 min	Action prioritisation	Sequence actions by materiality, dependency and implementation capacity.	30/60/90 priority sequence
20 min	Board decisions	Confirm risk treatment, funding, acceptance and reporting cadence.	Decision log with due dates
25 min	Implementation sequencing	Define first deliverables, evidence of completion and escalation thresholds.	Next-90-day delivery plan

Facilitator cue

Keep the group moving from information to decision. Capture disagreements in plain language and check every proposed action for owner, date, dependency, proof and failure response.

The review note is limited to the named scope

Use the information register to ask one question: what would have to be true for management to rely on this position?

RECORDED SELF-ASSESSMENT

Alert definitions for takeover indicators

Reviewer status recorded; see reviewer observation and limitations.

Decision to capture: what is the agreed boundary of reliance?

RECORDED SELF-ASSESSMENT

Approval and business justification

Reviewer status recorded; see reviewer observation and limitations.

Decision to capture: what is the agreed boundary of reliance?

RECORDED SELF-ASSESSMENT

Approved fraud-risk RACI

Reviewer status recorded; see reviewer observation and limitations.

Decision to capture: what is the agreed boundary of reliance?

RECORDED SELF-ASSESSMENT

Approved treatment plan with owners and due dates

Reviewer status recorded; see reviewer observation and limitations.

Decision to capture: what is the agreed boundary of reliance?

RECORDED SELF-ASSESSMENT

Audit-committee minutes showing independent reporting

Reviewer status recorded; see reviewer observation and limitations.

Decision to capture: what is the agreed boundary of reliance?

RECORDED SELF-ASSESSMENT

Chain-of-custody forms

Reviewer status recorded; see reviewer observation and limitations.

Decision to capture: what is the agreed boundary of reliance?

Priority findings should match operating reality

For each finding, ask whether the statement is accurate, what population it covers and what would prove the control is working.

01 Fraud Leadership and Governance: Management owns fraud risk, while internal audit or assurance functions provide independent review where they exist.

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

Challenge: What evidence would change the conclusion?

02 Fraud Incident Response: Evidence linked to suspected fraud is identified, preserved and handled appropriately.

This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.

Challenge: What evidence would change the conclusion?

Scenario resilience lens

ACTOR / OPPORTUNITY	Continuous Improvement and Fraud Risk Monitoring: Partially designed — Some elements exist, but implementation...
ENTRY POINT	The recorded control condition is engaged through Continuous Improvement and Fraud Risk Monitoring: The...
MECHANISM	Misuse can occur when an actor exploits the recorded control condition and controls decay...
CONTROL BYPASSED	A scheduled review reassesses fraud risks, tests whether key controls still operate as designed,...
CONCEALMENT	The activity may appear routine until complete population review, independent approval or exception monitoring...
CONSEQUENCE	Impact requires case-specific validation.; Operating impact requires case-specific validation.; Impact requires case-specific validation.; Operating...
WARNING INDICATORS	An exception, access, approval or incident record that cannot be reconciled to the complete...
CONTAINMENT	Escalate to CEO / Managing Director, preserve relevant records and apply the control's escalation...
LONG-TERM RESPONSE	The Head of Risk must run a scheduled review that revisits the fraud risk...

Visible trade-offs improve the chosen path

A decision is not complete until the group can explain what it is choosing, what it is giving up and how progress will be evidenced.

Approve accountable executive mandates and escalation authority for priority remediation.

Options and analysis

- Option A - retain accountability with the Finance Director (rejected: design and adjudication would sit with one executive): cost — Cost and effort require management confirmation before approval.; benefit — Builds durable ownership inside the organisation.; trade-off — Uses internal capacity and may move more slowly where capability is immature.; rejection reason — rejected: design and adjudication would sit with one executive
- Option B - delegate detection design to the Financial Controller with quarterly Audit and Risk Committee reporting (recommended and accepted): cost — Cost and effort require management confirmation before approval.; benefit — Adds focused specialist capacity against the named priority.; trade-off — Introduces external cost, handover effort and a dependency on clear scope.; recommended option
- Option C - outsource monitoring to an external provider (rejected at current maturity: Kestrel cannot yet specify the indicator set it needs): cost — Cost and effort require management confirmation before approval.; benefit — Combines internal accountability with targeted specialist support.; trade-off — Needs explicit boundaries so ownership and escalation are not diluted.; rejection reason — rejected at current maturity: Kestrel cannot yet specify the indicator set it needs

MK recommendation and rationale

MK recommendation: Viable options considered.

Option A - leave accountability with the Finance Director as the policy currently states. Trade-off: preserves the approved policy and needs no change control, but the Finance Director is already the escalation route for reported incidents, so the same executive would own both detection design and incident adjudication, which weakens independence. Option B - delegate detection design to the Financial Controller with quarterly Committee reporting. Trade-off: separates design from adjudication and uses an existing budgeted workstream; requires a minor policy amendment at the next review. Option C - outsource monitoring to an external provider. Trade-off: fastest route to coverage, but at this maturity Kestrel cannot yet specify what it wants monitored, so the provider would define the indicators and the organisation would not own them. Management decision: Option B accepted by the Finance Director on review. Owner: Financial Controller. Date: 30 November 2026 for the first quarterly report to the Committee.

Recommendation rationale: The recommendation follows the linked deterministic finding and risk priorities; management must confirm the final route, cost and delivery capacity.

Owner / deadline: CEO / Managing Director · 30 days

Decision / owner / date / failure response:

Accountable ownership converts decisions into action

The owner is the person who can make the operating change happen. The oversight function checks that the change is real and sustained.

PRIORITY ACTION	ACCOUNTABLE OWNER	OVERSIGHT	FIRST PROOF	FAILURE RESPONSE
Apply immediate escalation at "Any assurance reviewer assigned operational ownership of the control under review." and deliver the exact control design: The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes.	CEO / Managing Director	Audit Committee / Internal Audit	Approved fraud-risk RACI; Audit-committee minutes showing independent reporting; Internal audit charter or assurance mandate	Any assurance reviewer assigned operational ownership of the control under review.
Apply immediate escalation at "Any unexplained custody gap, integrity mismatch or unauthorised repository access." and deliver the exact control design: The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.	General Counsel / COO	Legal / Compliance	Chain-of-custody forms; Evidence register; Hash or seal records; Repository access log; Retention/legal-hold instruction	Any unexplained custody gap, integrity mismatch or unauthorised repository access.
Apply immediate escalation at "Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours." and deliver the exact control design: IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and Risk for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise.	Chief Technology Officer	Information Security / Internal Audit	Approval and business justification; Privileged-account register; Privileged-session/access logs; Quarterly independent recertification; Removal tickets	Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours.
Apply immediate escalation at "A material process unmonitored or a monitoring cycle missed without escalation." and deliver the exact control design: The monitoring owner	CFO / COO	Head of Risk	Coverage report against process fraud maps; Monitoring output for	A material unmonitored, or a monitoring

Sequencing protects dependencies and creates momentum

Sequence the work so foundational ownership, population definition and evidence production happen before effectiveness claims are made.

30 days

- Apply immediate escalation at "Any assurance reviewer assigned operational ownership of the control under review." and deliver the exact control design: The CEO and audit-committee chair must approve a RACI that assigns control operation to management and risk owners, reserves independent testing and unrestricted reporting for internal audit or equivalent assurance, and requires annual conflict review; the company secretary retains the approved RACI and minutes. · proof: Approved fraud-risk RACI; Audit-committee minutes showing independent reporting; Internal audit charter or assurance mandate · failure response: Any assurance reviewer assigned operational ownership of the control under review.

60 days

- Apply immediate escalation at "Any unexplained custody gap, integrity mismatch or unauthorised repository access." and deliver the exact control design: The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal. · proof: Chain-of-custody forms; Evidence register; Hash or seal records; Repository access log; Retention/legal-hold instruction · failure response: Any unexplained custody gap, integrity mismatch or unauthorised repository access.
- Apply immediate escalation at "Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours." and deliver the exact control design: IT Security maintains a complete privileged-account register, links each human and service account to an owner and approved justification, enforces separate named admin identities and MFA, records privileged sessions, and sends the full population quarterly to system owners and Risk for independent keep/remove certification; removals close within 24 hours for leavers and five business days otherwise. · proof: Approval and business justification; Privileged-account register; Privileged-session/access logs; Quarterly independent recertification; Removal tickets · failure response: Any unknown or

A usable decision record makes ownership durable

Decision record

Decision:

Options considered:

Selected path:

Owner:

Date:

Evidence of completion:

Action record

Action:

Accountable executive:

Process owner:

Oversight:

Dependency / escalation:

Next checkpoint:

The next checkpoint should show proof and ownership

Read the decisions back to the group. Confirm the owner, date, proof requirement and escalation route for every item that remains open.

Next checkpoint

Bring the annotated register, the completed proof items, the action-ageing view and the agreed effectiveness measures to the next management or board review.

- Named owners have accepted the actions.
- Dates and dependencies are recorded.
- Proof requirements are specific enough to use.
- Residual risk or unresolved information is explicit.
- The next checkpoint has a date and an audience.

Facilitator note: preserve the distinction between the recorded assessment, supplied information, management review notes and reviewer judgement in every follow-up pack.